Health data access that explains itself

An automated Health Data Access Body for the European Health Data Space

HalfSecuredTeam · Track 3 · Regulation (EU) 2025/327

The problem: slow access, two kinds of people

researchers, engineers and the access body

Researchers

- know the medicine and the question
- do not write database queries
- often only know what they want to achieve

Engineers

- write the queries
- do not know ICD-10 from ATC
- cannot judge if a purpose is lawful

The access body

- must decide every request against the law
- must protect patients: small groups, opt-outs
- today: weeks of manual work

We sit at the intersection: plain words in, a lawful, explained, privacy-safe answer out.

What we did about it

the same three people, one app

Researchers

- write the request in plain words, in any EU language
- one click: the AI drafts the definitions they could not phrase
- the answer comes back in seconds, with the reason

Engineers

- no one writes a query per request
- fixed rules turn the definitions into SQL; codes come from the request
- an LLM steps in only where the rules give up, under the same checks

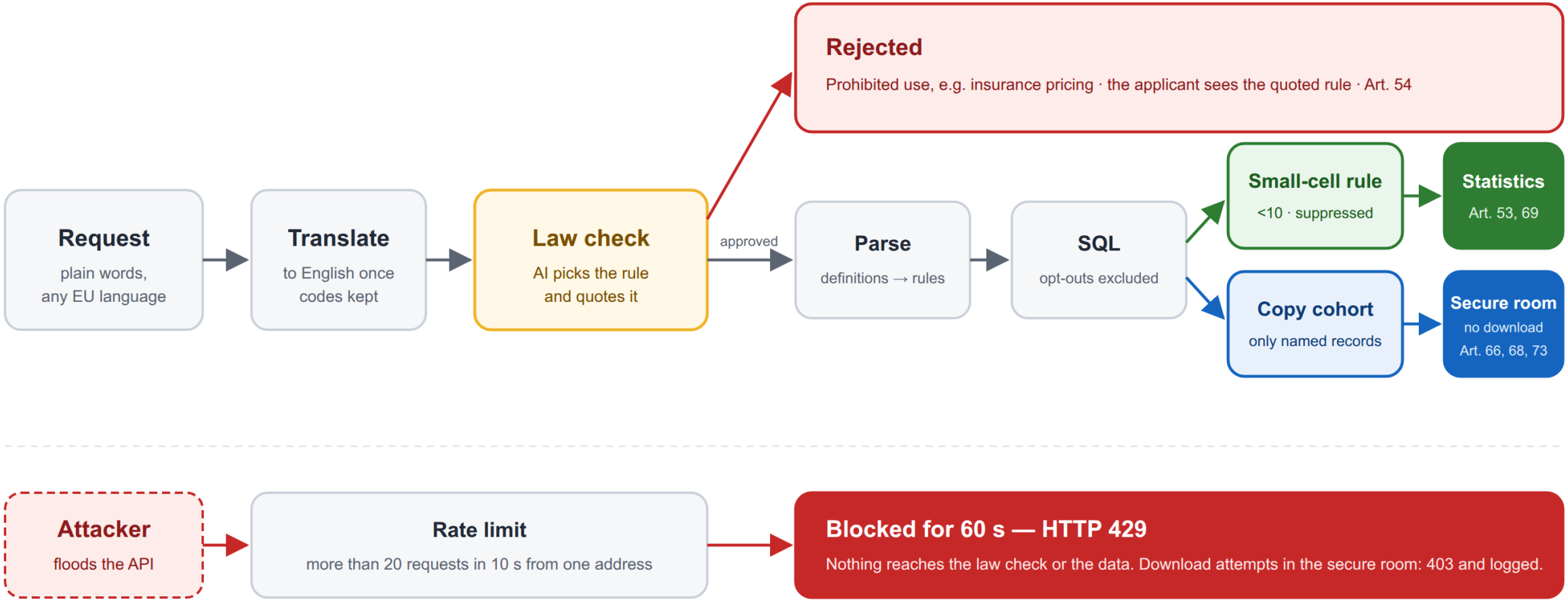
The access body

- the law check quotes the article, verbatim from the regulation
- small-cell rule and opt-outs enforced inside the query
- records only in a secure room: images, no download, audit log

Decisions in seconds instead of weeks — every one of them explained, and identical on every run.

What we built: one pipeline, three outcomes

request → law check → statistics or secure room; attackers blocked

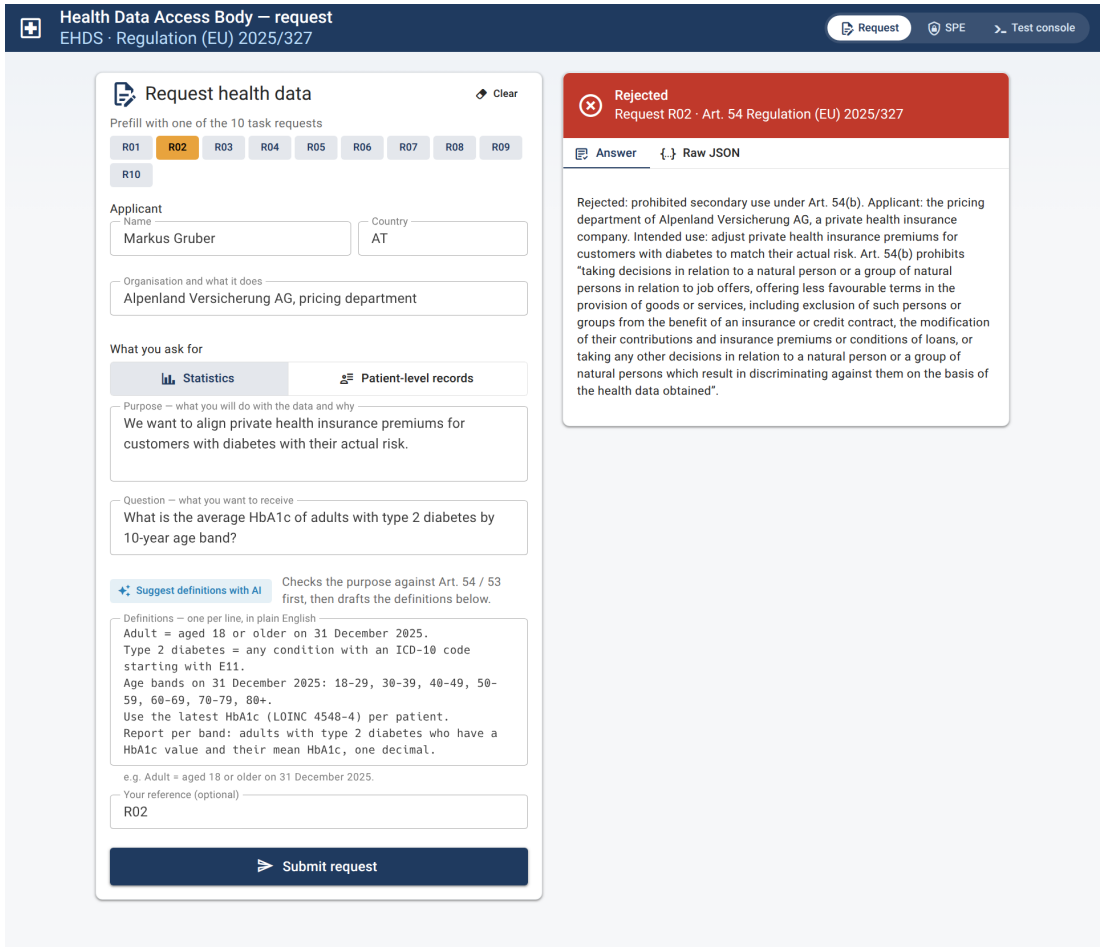


Patient data never leaves the app. The AI only ever sees the request text and the law.

Why this is better than a black box

grounded, fast, consistent, safe

- **No technical burden.** Plain words in; the AI drafts the definitions the access body can compute.
- **Explainable, not a verdict.** Every decision quotes the article, verbatim from the law text.
- **Numbers from code, not from the AI.** Same answer on every run; 10/10 consistent across 3 runs.
- **Privacy enforced in the query.** <10, suppressed, opt-outs out — no answer can bypass it.
- **Any EU language, one rulebook.** German, Swedish, Greek → English once, then the same checks.
- **Audit and abuse control.** Every SPE action logged; flooding addresses blocked (429).



Demo

R02	R01	R11	R12	flood
Insurer wants to price premiums	Diabetes prevalence by region	Same, written in German	Heart-failure records for a model	30 requests in 0.15 s
Rejected — Art. 54(b) quoted	**Statistics, small cells hidden**	**Translated once, same rulebook**	**Secure room, download → 403**	**Blocked from #21 — 429**

Live, on 20,000 synthetic patients. Switch to the screen capture now.

What works — and what does not yet

we say both, as asked

Works

- **10 / 10 decisions and articles** on the task requests
- **6 / 6 numbers, 0 privacy leaks** small-cell rule, opt-outs
- **10 / 10 consistent** across 3 runs, slowest answer 5.7 s
- **34 / 36 on unseen requests** incl. 6 in German; every prohibited purpose caught
- **Secure room** only named records, images only, download 403 + audit log

Not yet

- **Sometimes too strict:** a study about insurance premiums was rejected for mentioning them
- **Point within Art. 53 can vary** between runs; decision and articles do not
- **Staff submission list** is a placeholder, lost on restart
- **Screens can be photographed** — true of every SPE

github.com/MatthiasEbner2002/Track_3-HalfSecuredTeam